GLOBAL SIGMA PUBLIC STANDARD - Official Research Validation Edition

Ofifcial Research Validation Edition — Standard for Discussion and Validation (2026–2027)

Open Framework for Certification of High-Risk AI Systems

EXECUTIVE SUMMARY

Global Sigma v3.0 is a consolidated, operationalized, and auditable certification framework for high-risk AI systems. It operationalizes 12 fundamental principles (P1–P12) derived from international frameworks (EU AI Act, OECD, UNESCO, NIST, ISO/IEC, EC Guidelines) into verifiable, measurable requirements with reproducible audit methodology.

Key Innovation: Distinguishes **Technical Conformity** (voluntary, no immutability required) from **Certification** (mandatory for T3/T4, requires immutability for forensic proof).

TABLE OF CONTENTS

PRELIMINARY

- Development, Authorship, Governance and Licensing
- Introduction
- Foreword

PARTS

- **PART 1**: Scope and Applicability (1.1-1.6)
- **PART 2**: Foundational Concepts (2.1-2.3)
- **PART 3**: The Twelve Fundamental Principles P1–P12 (3.1-3.12)
- **PART 4**: Risk Tier Classification and Certification Logic (4.1-4.12)
- **PART 5**: Audit and Evaluation Methodology (5.1-5.10)
- **PART 6**: Normative Annexes (A-M)

CLOSING

- Closing Note
- Document Metadata

Development and Authorship

Primary Author & Lead Researcher: Dr. Paula Melissa Alfaro Montero.

This standard was developed as an original synthesis and technical consolidation of existing international AI governance frameworks. While the normative sources below provided the regulatory foundation, the **Global Sigma architecture, the deterministic thresholds, and the validation methodology** are the original intellectual work of Dr. Alfaro Montero.

Primary Normative Sources:

- European Commission Ethics Guidelines for Trustworthy AI (2019)
- OECD Recommendation on Artificial Intelligence (2019, updated 2024)
- ISO/IEC 23894 AI Risk Management (2023); ISO/IEC 24029 AI Robustness (2021)
- EU Regulation 2024/1689 (AI Act) (2024)
- UNESCO Recommendation on the Ethics of AI (2021)
- NIST AI Risk Management Framework (2023)

Governance Structure (The Sunset Model)

To ensure global trust and prevent regulatory capture, the project follows a strict separation of powers:

- **Scientific Authorship:** Dr. Alfaro Montero retains lifelong moral and scientific authorship of the Global Sigma Standard.
- **Institutional Independence:** Upon validation, the governance, maintenance, and updates of the Standard will be transferred to the **Guardian Foundation**, a neutral, independent non-profit entity.
- **Decoupling:** Dr. Alfaro Montero will not hold a seat on the Foundation's Board of Directors, ensuring that the "Rule-Maker" (Foundation) and the "Tool-Provider" (the Author's private auditing firm) remain independent.

3. Licensing and Use Rights (Public Good vs. Private IP)

- **The Global Sigma Standard (Public Asset):** Licensed under **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**. This allows for free use, reproduction, distribution, and translation with attribution to Dr. Alfaro Montero and the Guardian Foundation.
- **Validation Tooling & Software (Reserved IP):** The technical implementations developed are **reserved intellectual property of Dr. Alfaro Montero**. These are not part of the public license and will form the basis for commercial high-assurance auditing services.

INTRODUCTION

The Challenge: Gap in AI Governance

AI systems now operate as critical infrastructure. Existing governance frameworks are fragmented:

Legal Frameworks (EU AI Act, sectoral): Mandate compliance but vague on technical implementation

Guidance Frameworks (OECD, UNESCO, NIST): Aspirational but lack auditable criteria

Management Systems (ISO 42001): Address governance, not technical verification

Result: Organizations cannot objectively demonstrate conformity with multiple frameworks simultaneously.

Global Sigma's Response

Global Sigma **consolidates, operationalizes, and certifies**:

1. **Consolidates**: 12 coherent principles from 6+ international frameworks
2. **Operationalizes**: Transforms aspirational principles into verifiable properties
3. **Certifies**: Provides independent third-party verification where others provide only guidance

Critical: Global Sigma does NOT substitute for legal frameworks—it provides the technical certification mechanism they lack.

How This Standard Works

Three Integrated Components:

1. **12 Operationalized Principles (P1–P12)**

- P1–P5: Transparency, reproducibility, auditability
- P6–P9: Validation, modularity, governance, ethics
- P10–P12: Resilience, fairness, security

2. **Risk-Tier Classification (Tier 1–4)**
   - Tier 1: Minimal (N/A)
   - Tier 2: Limited (Voluntary certification)
   - Tier 3: High (Mandatory)
   - Tier 4: Critical (Mandatory + enhanced scrutiny)
3. **Reproducible Audit Methodology**
   - 6 phases: Scope → Evidence → Evaluation → Veto ID → Aggregation → Decision
   - Independent verification, no proprietary tools

FOREWORD

AI systems are transitioning from experimental tools to critical infrastructure. Global Sigma provides the certification-grade framework needed to translate aspirational principles into verifiable, auditable, enforceable requirements.

What This Standard Does

1. Operationalizes P1–P12 principles with verifiable properties
2. Enables consistent risk tier classification
3. Supports independent certification
4. Consolidates multiple frameworks into unified requirements
5. Distinguishes technical conformity (voluntary) from certification (mandatory for T3/T4)

What This Standard Does NOT Do

- ❌ Substitute for legal/regulatory frameworks (EU AI Act, NIST, sector regulations)
- ❌ Prescribe technical architectures
- ❌ Provide organizational management system guidance (ISO 42001)
- ❌ Guarantee safety or eliminate risk
- ❌ Require all systems to seek certification

Critical Distinction: Technical Conformity vs. Certification

Technical Conformity: P1–P12 adherence, no immutability, no formal auditor. Suitable for in-development systems and internal governance.

Certification: Technical conformity + immutability mechanisms (T3/T4) + implementation audit. Suitable for regulatory compliance and procurement.

Status

Research Validation Edition (2026–2027). Quantitative thresholds (≥95% reproducibility, ≥0.80 disparate impact) are aspirational targets pending operational validation.

PART 1: SCOPE AND APPLICABILITY

1.1 What This Standard Covers

Applies to AI Systems classified as:

- **Tier 3 (High-Risk)**: Certification MANDATORY (if regulated jurisdiction applies)
- **Tier 4 (Critical-Risk)**: Certification MANDATORY with enhanced scrutiny
- **Tier 2 (Limited-Risk)**: Certification VOLUNTARY

Addresses: design, architecture, technical properties, auditability, fairness, security, resilience.

1.2 Applicability Criteria

System in scope if it:

- Operates with autonomy to generate predictions, recommendations, or decisions
- Influences physical/digital environments materially
- Affects individuals, organizations, or society significantly

1.3 Certification Scope vs. Technical Conformity

Path 1: Technical Conformity (Optional)

- Demonstrate P1–P12 adherence
- Traceability required; immutability optional
- NO formal auditor required
- Suitable for in-development, internal governance

Path 2: Formal Certification (Mandatory T3/T4 in regulated contexts)

- Independent Certification Body audit
- Immutability mechanisms required (T3/T4)
- Design Conformity Seal and/or Implementation Certification
- Suitable for regulatory compliance, procurement

1.4 What This Standard Does NOT Cover

Out of scope:

- Tier 1 (Minimal-Risk) systems
- Systems with active sector-specific regulation (unless explicitly referenced)
- Pure research/lab systems
- Controlled, non-consequential environments

1.5 Intended Audience

- Certification bodies and independent auditors
- Regulatory authorities
- Organizations deploying high-risk AI Systems
- Internal governance and compliance teams

1.6 Relationship to Other Frameworks

Framework	Type	Status	Global Sigma Role
EU AI Act	Legal	Mandatory Aug 2026	Operationalizes Articles 9–15
NIST RMF	Guidance	Federal standard	Aligns with Measure/Manage phases
ISO 42001	Management	Voluntary	Complements organizational controls

OECD Principles	Consensus	Non-binding	Operationalized through P1–P12
UNESCO Ethics	Guidance	Non-binding	Operationalized through P1–P12

Legal Status: Global Sigma certification demonstrates technical conformity but does NOT replace legal compliance obligations.

PART 2: FOUNDATIONAL CONCEPTS

2.1 Design Philosophy

Technology-Agnostic: Defines WHAT, not HOW. Multiple architectures satisfy principles.

Risk-Tiered: Impact, irreversibility, human dependency vary; requirements scale accordingly.

Operationalized: Aspirational principles → verifiable properties with explicit criteria.

Consolidating: Unifies EC, OECD, ISO, UNESCO, EU AI Act into coherent requirements.

Scientific Rigor: Technical Conformity assessed against current State-of-the-Art in AI Safety.

2.2 Key Distinctions

Technical Conformity vs. Certification

- Conformity: P1–P12 adherence (no immutability, no formal auditor)
- Certification: Conformity + immutability (T3/T4) + implementation audit

Traceability vs. Immutability

- **Traceability** (Design Standard): Architectural capacity to track data/decisions/states. Required for all. Enables audit.
- **Immutability** (Forensic Standard): Cryptographic/physical guarantee logs cannot be altered. Required only for certification. Provides forensic proof.

Key Point: System can be fully traceable but not immutable. Traceability enables audit; immutability enables certified proof.

Remediable vs. Irremediable Vetoes

- Remediable: Correctable without architectural redesign
- Irremediable: Requires complete restructuring; certification denied

Design Conformity vs. Implementation Audit

- Design Conformity: Seal indicating design meets P1–P12
- Implementation Audit: Verification deployed system implements sealed design

2.3 Certification Eligibility

Mandatory Certification (T3, T4):

- Deployed in regulated jurisdictions (EU AI Act applies)
- Required by procurement/legal obligation
- Autonomous decisions affecting fundamental rights

Voluntary Certification (T2):

- Market differentiation
- No legal mandate

Exempt (T1):

- Minimal-risk systems

In-Development Systems (Validation Phase):

- Technical conformity permitted
- Immutability not required until certification sought
- Traceability still required

PART 3: THE TWELVE FUNDAMENTAL PRINCIPLES (P1–P12)

3.1 P1 — Structural Transparency

Requirement: Full traceability of input → processing → decision → justification.

Verifiable Properties: Actor Identification, Functional Decomposition, Decision Logic Specification, Data Traceability, Auditor Readability.

Validation Criteria:

- ✅ COMPLIANT: 5/5 met
- ⚠️ PARTIALLY: 3–4/5 met
- ❌ NON-COMPLIANT: ≤2/5 → Veto D1

3.2 P2 — Reproducible Determinism

Requirement: Identical inputs/state → identical outputs. Randomness documented and isolated.

Verifiable Properties: Complete Versioning, Input Capture, Verifiable Reproduction, Explicit Randomness Control.

Exception for Continuous Learning Systems:

Systems with legitimate continuous learning (reinforcement learning, online learning, adaptive systems) demonstrate reproducibility through versioned decision windows:

- Explicit version IDs per decision epoch (e.g., "Model v1.234")
- Reproducibility within version window (≥95% threshold applies)
- Version transitions logged and validated (P6)
- Audit trail: [timestamp] → [version] → [inputs] → [outputs]

Additional requirements:
☑️ Documented transition triggers
☑️ Pre-deployment validation (P6)
☑️ Rollback capability

This exception does NOT apply to unexplained variation or non-functional randomness.

Validation Criteria:

- ✅ COMPLIANT: 4/4 + ≥95% reproduction across 30 decisions
- ⚠️ PARTIALLY: 3/4 + 80–94% reproduction
- ❌ NON-COMPLIANT: ≤2/4 or <80% → Veto D2 (Irremediable)

3.3 P3 — Knowledge Sovereignty

Requirement: Knowledge controlled by organization, portable via open formats, auditable by third parties.

Verifiable Properties: Access and Control, Open Formats, Vendor Independence, Dependency Documentation.

Validation Criteria:

- ✅ COMPLIANT: Full access + proven portability
- ⚠️ PARTIALLY: Limited access/partial portability

- ❌ NON-COMPLIANT: Complete lock-in → Irremediable

3.4 P4 — Right to Explanation

Requirement: Every decision generates automatic, complete, human-readable, independently verifiable explanation.

Verifiable Properties: Automatic Generation, Completeness, Readability, Verifiability.

Validation Criteria:

- ✅ COMPLIANT: 4/4 + confirmed readable
- ⚠️ PARTIALLY: 3/4 → Remediable via P7
- ❌ NON-COMPLIANT: ≤2/4 → Remediable via P7

3.5 P5 — Continuous Auditability

Requirement: All decisions/changes/events tamper-evident, traceable, version-linked, independently verifiable.

Verifiable Properties: Tamper-Evidence, Traceability, Version-Linkage, Independent Verification.

Validation Criteria:

- ✅ COMPLIANT: Integrity verified; logs accessible
- ⚠️ PARTIALLY: 3/4 properties → Remediable with P7
- ❌ NON-COMPLIANT: ≤2/4 → Irremediable without P7

3.6 P6 — Validated Learning

Requirement: System changes undergo formal validation prior to deployment. No ethical/safety degradation permitted.

Verifiable Properties: Validation Protocol, Safety Threshold, No Bypass Mechanism, Continuous Monitoring.

Validation Criteria:

- ✅ COMPLIANT: Formal protocol + zero unvalidated changes
- ⚠️ PARTIALLY: Protocol with minor gaps → Remediable
- ❌ NON-COMPLIANT: No validation or systematic bypass → Irremediable

Validation for Continuous Learning Systems:

For systems under P2 continuous learning exception:

Validation frequency:

- Before each version transition
- Minimum every 30 days (Tier 4)
- Minimum every 90 days (Tier 3)
- Upon anomalous behavior

Validation verifies:

1. No ethical degradation (P9 maintained)
2. No fairness degradation (P11 DI ≥0.80 maintained)
3. No safety degradation (P10 maintained)
4. Explainability maintained (P4)

Upon failure: rollback, escalate (P8), document (P5), halt transition.

3.7 P7 — Intervention-Ready Modularity

Requirement: Architecture allows component-level replacement without full reengineering.

Verifiable Properties: Modular Architecture, Clear Interfaces, Replacement Coordination (<20% redesign), Dependency Mapping.

Critical Function: P7 determines if other vetoes are remediable (P7 Compliant) or irremediable (P7 Non-Compliant).

Validation Criteria:

- ✅ COMPLIANT: <20% coordination
- ⚠️ PARTIALLY: 20–50% coordination
- ❌ NON-COMPLIANT: Monolithic; >50% redesign

3.8 P8 — Multi-Level Governance

Requirement: High-risk decisions automatically escalate to human oversight when predefined conditions met.

Verifiable Properties: Escalation Triggers, Automatic Escalation, Service Level Agreements, Escalation Logs.

Immutability Requirement: Authorization logs, policy changes, "human-in-the-loop" decisions preserved immutably for forensic proof.

Validation Criteria:

- ✅ COMPLIANT: ≥95% escalations within SLA
- ⚠️ PARTIALLY: 85–94% → Veto D4 (Remediable)
- ❌ NON-COMPLIANT: <85% or bypass → Veto D4 (Irremediable)

3.9 P9 — Verifiable Ethics

Requirement: System blocks autonomous decisions in unresolved ethical dilemmas; escalates to human ethical oversight.

Verifiable Properties: Ethical Dilemma Catalog, Blocking Mechanism, Escalation Protocol, Dispute Resolution.

Validation Criteria:

- ✅ COMPLIANT: Comprehensive catalog + blocking verified
- ⚠️ PARTIALLY: Incomplete catalog
- ❌ NON-COMPLIANT: No blocking → Irremediable (Tier 4)

3.10 P10 — Certifiable Resilience

Requirement: System demonstrates verified recoverability with defined RTO and RPO.

Verifiable Properties: Resilience Testing, RTO Definition, RPO Definition, Recovery Verification.

Validation Criteria:

- ✅ COMPLIANT: ≥95% recovery tests pass; RTO/RPO met
- ⚠️ PARTIALLY: 80–94% tests → Remediable
- ❌ NON-COMPLIANT: <80% or unmet → Irremediable

3.11 P11 — Fairness and Data Governance

Requirement: System measures, mitigates, monitors, documents disparate impact across protected groups.

Verifiable Properties: Protected Group Identification, Impact Measurement, Mitigation Measures, Continuous Monitoring, Documentation.

Disparate Impact Ratio: (Selection Rate Protected Group) / (Selection Rate Reference Group)

Immutability Requirement: Data lineage, bias-mitigation records, fairness metrics anchored to immutable record.

Validation Criteria:

- ✅ COMPLIANT: Ratio ≥0.80 (four-fifths rule)
- ⚠️ PARTIALLY: 0.50–0.79 → Remediable if P7 compliant
- ❌ NON-COMPLIANT: <0.50 → Irremediable

3.12 P12 — Adversarial Security and Robustness

Requirement: System demonstrates resistance to adversarial inputs, manipulation, exfiltration via verified testing.

Verifiable Properties: Attack Surface Identification, Adversarial Testing, Defense Documentation, Continuous Evaluation.

Testing Scope: Input perturbation, model extraction, data poisoning, evasion, backdoor detection.

Immutability Requirement: Adversarial testing, vulnerability assessments, security patches recorded immutably.

Validation Criteria:

- ✅ COMPLIANT: ≥80% attack surfaces protected
- ⚠️ PARTIALLY: 60–79% → Remediable
- ❌ NON-COMPLIANT: <60% → Critical veto

PART 4: RISK TIER CLASSIFICATION AND CERTIFICATION LOGIC

4.1 Risk Tier Framework

Tier	Classification	Certification	Description
1	Minimal Risk	Not Applicable	Negligible impact
2	Limited Risk	Voluntary	Reversible consequences
3	High Risk	MANDATORY*	Significant impact; human-dependent
4	Critical Risk	MANDATORY (enhanced)	Irreversible harm; life/safety/rights impact

- Only if regulated jurisdiction or legal obligation applies.

4.2 Mandatory vs. Voluntary Certification Scope

Mandatory: All T3 (if legal obligation) + all T4

Voluntary: T2 systems + T3 without legal mandate

Technical Conformity (no certification): All orgs may demonstrate P1–P12 adherence; no immutability required.

4.3 Principle Evaluation Matrix

Each system evaluated against P1–P12. For each:

- Principle ID
- Evaluation Result (Compliant / Partially / Non-Compliant)
- Evidence Provided
- Gaps Identified
- Veto Classification

Uses mandatory Annex A template.

4.4 Veto Logic and Classification

Definition: Certification-blocking condition when principle fails minimum criteria.

Veto Types:

- **Remediable**: Correctable without architectural redesign
- **Irremediable**: Requires complete restructuring; certification denied

P7 Determinative Function:

- P7 Compliant → most vetoes may be remediable
- P7 Non-Compliant → vetoes default to irremediable

4.5 Severity Weighting Model

Severity	Impact	Reversibility	Human Harm
Low	Localized	Easy	None
Medium	Systemic/reversible	Partial	Potential
High	Systemic/irreversible	Cannot	Actual

Rule: Highest dimension score determines overall severity.

4.6 Final Risk Tier Determination

Aggregation Logic: Failed principles count + severity levels + irremediable veto presence + human oversight dependency + systemic irreversibility.

Escalation to Tier 4 if:

- ≥1 irremediable veto exists
- Multiple high-severity failures
- Autonomous decisions affect fundamental rights/physical safety
- System cannot be safely interrupted

Downgrade Constraints: NOT via documentation alone; requires verified remediation + independent re-evaluation.

4.7 Certification Outcomes

Outcome	Description
Certified	All principles met; no irremediable vetoes
Conditionally Certified	Remediable vetoes + approved remediation plan
Not Certified	≥1 irremediable veto

4.8 Certification Validity and Re-Certification

Valid for: **12 months** OR **until material system change** (whichever first).

Material changes trigger mandatory re-certification (Annex F).

4.9 Design Conformity Audit vs. Implementation Audit

Design Conformity Audit: Evaluates design/architecture/specifications against P1–P12, independently of implementation.

Result: Design Conformity Seal (does NOT constitute certification by itself).

Implementation Conformity Audit: Evaluates deployed system faithfully implements sealed design.

Certification granted only upon successful Implementation Audit.

Separation of Audit Functions: May be conducted by different independent entities if:

- Independence/impartiality maintained

- Reference design clearly identified and immutable
- Methodology consistent with standard

Reference Design Integrity: Preserved with integrity, traceability, non-alteration via Custody Repository.

Certification Against Sealed Design:

- Implementation Audit verifies alignment
- Deviations treated as material non-conformities
- Certification decisions reference design version audited

4.10 Design Immutability Requirement (DIR) for Certification

Definition: Technical requirement for non-repudiable evidence. Establishes functional criteria operational data must meet for Implementation Certification.

Functional Objectives (regardless of technology):

- **Tamper-Evidence**: Alteration/deletion/injection attempts detectable by independent auditor
- **Sequential Integrity**: Chronological order of events preserved and verifiable; prevents backdating
- **Data Persistence**: Evidence accessible and unalterable for certification validity period

Technological Neutrality: Any architecture (distributed, centralized, hardware) acceptable if meets objectives.

Acceptable mechanisms:

- Cryptographic hashing with third-party custody
- Blockchain-based artifact registries
- Notarized digital signatures
- Hardware security modules (HSMs)
- Institutional multi-party custody

Implementation Threshold:

- **Design Conformity Seal**: Requires Traceability (ability to generate logs)
- **Implementation Certification**: Requires Immutability (guarantee logs cannot change)

Mandatory for Certified T3/T4 Systems: Immutability mechanisms covering certified design artifacts, compliance evidence, audit records.

Critical Distinction: Immutability required ONLY for certification. Technical conformity does NOT require it.

Objectives of Immutability:

1. **Forensic Guarantee**: Preserve design/evidence in tamper-evident state for post-incident/regulatory analysis
2. **Compliance Evaluation**: Enable objective, repeatable, externally verifiable assessment of conformity

Veto Correlation: If implementation audit reveals operational logs can be modified without forensic trail → system fails DIR → Irremediable Veto D11.

Not Required for Technical Conformity: In-development systems, research projects, internal governance may pursue P1–P12 without immutability overhead.

4.11 Transparency and Public Disclosure Obligations

Certifying body SHALL publish:

- Evaluation criteria
- Aggregation methodology
- Severity definitions

- Certification decision rationale
- Final Risk Tier
- Validity period and conditions

Sensitive/proprietary details may be redacted; reasoning shall NOT be.

4.12 Institutional Integrity and Independence

Sealing Authority: Any entity authorized by Governing Authority may issue Design Conformity Seal.

Mandatory Design Deposit: Upon issuing Seal, entity MUST deposit full Sealed Design into official Custody Repository (Single Source of Truth for audits).

Certification Authority: Only accredited Certification Bodies may issue Implementation Certification.

Separation of Duties:

- Certification Body may perform both Design Sealing and Implementation Certification for same system
- **Prohibition**: Certification Body SHALL NOT participate in actual design/development of AI system it certifies. Any involvement nullifies certification.

Audit Integrity: Certification Body MUST perform implementation audit using Sealed Design retrieved directly from Custody Repository to prevent unauthorized modifications.

PART 5: AUDIT AND EVALUATION METHODOLOGY

5.1 Certification Architecture

Certification conducted by independent Certification Body using explicit, reproducible, published methodology.

Methodology shall NOT depend on:

- Proprietary tools
- Vendor-specific platforms
- Undisclosed scoring mechanisms

5.2 Roles and Responsibilities

Certification Body SHALL:

- Define and publish evaluation criteria
- Apply methodology consistently
- Maintain auditor independence
- Issue certification decisions
- Retain audit documentation minimum 5 years
- Not certify systems it designed/implemented

Independent Auditor SHALL:

- Have no financial/operational ties to provider
- Follow published methodology strictly
- Document all findings/evidence
- Escalate vetoes without discretion
- Conduct evaluations independently

Deploying Organization SHALL:

- Provide full access to required evidence

- Ensure system availability for audit
- Declare material changes
- Implement approved remediation plans
- Maintain traceability during operation

5.3 Audit Phases

Phase 1: Scope Definition

- System boundaries and decision types
- Risk tier hypothesis
- Regulatory context
- Intended audience

Phase 2: Evidence Collection

- System architecture documentation
- Data governance artifacts
- Decision logs (≥30 historical)
- Versioning records
- Incident reports
- Vendor contracts/dependencies

Phase 3: Principle Evaluation (P1–P12)

- Defined criteria
- Objective thresholds
- Explicit acceptance conditions
- Mandatory Annex A matrix

Phase 4: Veto Identification

- Explicitly identified
- Classified (Remediable/Irremediable)
- Severity-weighted
- No suppression/offsetting

Phase 5: Risk Tier Aggregation

- Failed principles count
- Severity levels
- Irremediable veto presence
- Human oversight dependency

Phase 6: Certification Decision

- Certification outcome
- Validity period
- Conditions
- Remediation obligations

5.4 Evidence Standards

Acceptable Evidence: Verifiable, timestamped, version-linked, traceable.

Formats: Audit logs, reports, test results, structured documentation.

Note on Immutability: For CERTIFICATION (not technical conformity), evidence additionally preserved via immutability mechanisms (Section 4.10).

Unacceptable Evidence: Marketing claims, self-assessments without verification, undocumented assertions, proprietary black-box scores.

5.5 Reproducibility Requirements

Methodology SHALL enable: Re-execution by independent auditors; consistent conclusions under identical conditions.

Statistical Thresholds (aspirational):

- Quantitative: Cohen's Kappa ≥0.90
- Qualitative: ≥85% agreement
- Hybrid: Both thresholds met

Failure to meet thresholds invalidates methodology, not system.

5.6 Handling Uncertainty

- Explicitly document
- Apply conservative assumptions (favor non-certification)
- Do NOT resolve in favor of certification

5.7 Remediation Process

For Remediable Vetoes, Deploying Organization submits:

- Root cause analysis
- Corrective actions
- Timeline
- Verification method

Re-Audit: All remediations independently verified. Partial remediation NOT accepted.

5.8 Conflict Resolution

1. Methodology review
2. Evidence re-examination
3. Independent third-party arbitration

5.9 Documentation and Records

All audit artifacts retained MINIMUM 5 years:

- Evidence
- Evaluation matrices
- Auditor notes
- Certification decisions

5.10 Public Transparency

Certification Body SHALL publish:

- Methodology overview

- Certification scope (system description)
- Final Risk Tier
- Validity period and conditions
- Rationale for major decisions

Sensitive details may be redacted; reasoning shall NOT be.

PART 6: NORMATIVE ANNEXES

ANNEX A — Evaluation Matrix Template

Mandatory for all audits:

Principle	Result	Evidence	Gaps	Veto	Severity
P1-P12	Compliant/Partially/Non-Compliant	[describe]	[identify]	[type]	Low/Med/High

ANNEX B — Veto Classification Framework

Remediable Veto Criteria:

- Non-compliance correctable without architectural redesign
- P7 compliant (unless explicitly justified)
- Remediation path clear/feasible

Irremediable Veto Criteria:

- Non-compliance requires fundamental restructuring
- P7 non-compliant (unless explicitly justified)
- No feasible remediation

P7 Default Rule: If P7 non-compliant, all other failures default to irremediable unless explicitly/independently justified.

Veto Catalog:

- **D1** (P1): ≤2/5 verifications → Remediable via P7
- **D2** (P2): <80% reproduction → Irremediable
- **D3** (P5): ≤2/4 properties → Remediable via P7
- **D4** (P8): <85% escalations → Irremediable
- **D11** (P2/P5): Logs modifiable without trail → Irremediable (Certification only)

Severity Assessment: Across Impact, Reversibility, Human Harm. Highest dimension determines overall.

ANNEX C — Disparate Impact Measurement Protocol

Formula: (Selection Rate Protected Group) / (Selection Rate Reference Group)

Acceptance Criterion (aspirational): ≥0.80 (four-fifths rule)

Steps: Identify groups → Calculate rates → Compute ratio → Document

Jurisdictional Variation: Protected groups per applicable law (EU, US, national, local).

ANNEX D — Reproducibility Validation Protocol

Procedure:

1. Select ≥30 historical decisions

2. Obtain identical inputs/state
3. Re-execute under controlled conditions
4. Compare outputs
5. Measure consistency
6. Document discrepancies

Acceptance Criterion (aspirational): ≥95% identical outputs

ANNEX E — Acceptable Evidence Catalogue

Minimum Requirements:

- Decision logs (≥30 timestamped)
- Version histories
- Architecture documentation
- Audit trails
- Test results
- Data governance policies
- Escalation logs
- Vendor documentation
- Immutability verification

ANNEX F — Material Change Definition

Material if affects:

- Decision logic/algorithm
- Training data/sources
- Model architecture/parameters
- Risk tier classification
- Regulatory applicability
- Immutability mechanism

Triggers mandatory re-certification.

ANNEX G — Immutability Implementation Guidance

Preserves:

1. Design artifacts/specifications
2. Compliance evidence/test results
3. Audit logs/decision records
4. System state transitions

Acceptable Technologies:

- Cryptographic hashing with timestamp authorities
- Blockchain-based registries
- Notarized digital signatures
- Hardware security modules (HSMs)
- Institutional multi-party custody

- Append-only databases

Implementation Patterns:

- **Pattern 1: Cryptographic Custody** - Third-party timestamps; org retains logs
- **Pattern 2: Distributed Consensus** - Blockchain/ledger with multiple nodes
- **Pattern 3: Hardware-Based** - HSM/TPM with tamper-detection
- **Pattern 4: Institutional** - Multiple sealed copies; legal witness

ANNEX H — Normative Language Guide

Term	Meaning
shall	Mandatory
should	Recommended
may	Permitted
must	Mandatory (stronger)
will	Future state

ANNEX I — Glossary

AI System: Machine-based system with autonomy generating predictions/recommendations/decisions affecting environments.

AI System (Operational Scope for Evaluation)

For evaluation under this standard, "AI System" comprises:

In Scope:

- Inference engine (deployed model, parameters, rules)
- Decision logic (transformations, processing)
- Input/output interfaces (APIs, pipelines)
- Explanation mechanisms (P4)
- Governance controls (P8, P9 escalation/blocking)
- Runtime environment (configuration, dependencies)

Explicitly Excluded:

- Historical training datasets (token-by-token audit excluded)
- Development infrastructure (pre-deployment tools)
- Organizational processes (except implementing P7/P8/P9)

Rationale: Evaluates observable system behavior, not training data provenance. Enables practical auditability.

Data Governance: Training data excluded from direct audit, but systems MUST demonstrate (P11): data governance, bias measurement, fairness metrics (DI ≥0.80), monitoring.

Distinction: We evaluate how the system behaves, not every training token.

Certification: Formal attestation confirming P1–P12 conformity, immutability (T3/T4), and implementation audit.

Technical Conformity: P1–P12 adherence without immutability or formal certification.

Design Conformity Seal: Design specification meets P1–P12 requirements.

Design Immutability Requirement (DIR): Technical requirement for non-repudiable evidence (tamper-evidence, sequential integrity, data persistence).

Immutability Mechanism: Technical implementation providing verifiable tamper-evidence for design, compliance evidence, certification records. Required ONLY for T3/T4 certification.

Traceability: Ability to record and follow decision path; version control and audit trails. Required for all systems. Enables audit; does not guarantee immutability.

Material Change: Modification affecting decision logic, data sources, model architecture, risk tier, regulatory applicability, or immutability mechanism.

Veto: Certification-blocking condition triggered by principle non-compliance.

Veto D11: Immutability Failure veto (operational logs modifiable without forensic trail). Irremediable.

Disparate Impact Ratio: (Selection Rate Protected Group) / (Selection Rate Reference Group).

Protected Group: Category protected against discrimination under applicable law.

Remediable Veto: Non-compliance correctable without architectural redesign.

Irremediable Veto: Non-compliance requiring complete restructuring.

RTO (Recovery Time Objective): Maximum acceptable downtime after failure.

RPO (Recovery Point Objective): Maximum acceptable data loss from failure.

Sealed Design: Design specification locked via Design Conformity Seal; reference for Implementation Certification.

Custody Repository: Official repository maintaining Sealed Designs as Single Source of Truth.

ANNEX J — Global Sigma and Existing Frameworks

J.1 Purpose

Clarifies how Global Sigma relates to existing AI governance frameworks. Essential for multi-jurisdictional organizations.

J.2 Framework Landscape (January 2026)

Framework	Type	Jurisdiction	Status	Mandatory	Legal Force
EU AI Act	Legal	EU	Aug 2024; high-risk Aug 2026	YES	YES
NIST RMF	Guidance	US Federal	Jan 2023	De facto	NO
ISO 42001	Management	Global	Dec 2023	NO	NO
OECD Principles	Consensus	International	2019, updated 2024	NO	NO
UNESCO Ethics	Guidance	International	2021	NO	NO
EC Trustworthy AI	Pre-regulatory	EU	2019; superseded	Superseded	NO

J.3 Global Sigma's Position

What Global Sigma Does:

- Operationalizes aspirational principles into verifiable requirements
- Consolidates technical requirements into unified P1–P12
- Provides certification mechanism where frameworks provide guidance
- Translates legal mandates into auditable properties

What Global Sigma Does NOT Do:

- ❌ Substitute for EU AI Act, NIST, legal frameworks
- ❌ Provide organizational management guidance (ISO 42001)
- ❌ Prescribe technical architectures
- ❌ Guarantee safety or eliminate risk

J.4 Framework-Specific Relationships

EU AI Act (Regulation 2024/1689)

Status: Mandatory August 2, 2026 (high-risk systems)

Global Sigma operationalizes Articles 9–15 through P1–P12. Certification demonstrates technical conformity but does NOT replace full EU AI Act compliance (governance, Notified Body assessment, CE marking, post-market monitoring remain org responsibility).

NIST AI RMF

Status: De facto US federal procurement standard (non-binding)

Global Sigma aligns with NIST's Measure phase through quantified, auditable properties. Federal agencies may reference Global Sigma certification in procurement.

ISO/IEC 42001:2023

Status: Voluntary international management system standard

Complementary: ISO 42001 addresses organizational governance; Global Sigma addresses technical verification. Dual certification possible (organizational + technical).

OECD AI Principles

Status: Non-binding international consensus (G20 endorsed)

Global Sigma directly operationalizes all five OECD principles through P1–P12.

UNESCO Ethics Recommendation

Status: Non-binding international ethical guidance

Global Sigma operationalizes all ten UNESCO principles through P1–P12.

EC Trustworthy AI Guidelines

Status: Pre-regulatory (2019); superseded by EU AI Act

Direct 1:1 mapping between EC dimensions and Global Sigma principles.

J.5 Consolidated Framework Mapping

Global Sigma Principle	EU AI Act	NIST RMF	OECD	UNESCO	EC Ethics	ISO 23894
P1 Transparency	Art. 13	Measure	Transparency	Transparency	Transparency	Traceability
P2 Determinism	Art. 15	Measure	Robustness	Safety	Robustness	Verification
P3 Sovereignty	Art. 10	Govern	Human-centricity	Privacy	Privacy	Data gov
P4 Explanation	Art. 13	Measure	Transparency	Individual Rights	Transparency	Traceability
P5 Auditability	Art. 12	Manage	Accountability	Governance	Accountability	Governance
P6 Learning	Art. 9	Measure	Reliability	Data Quality	Robustness	Monitoring
P7 Modularity	Art. 14	Govern	Human Control	Accountability	Human Oversight	Architecture
P8 Governance	Art. 14	Govern	Accountability	Multi-Stakeholder	Human Oversight	Governance
P9 Ethics	Art. 14	Measure	Values/Fairness	Do No Harm	Human Oversight	Risk assessment
P10 Resilience	Art. 15	Manage	Robustness	Safety	Robustness	Business continuity
P11 Fairness	Art. 10	Measure	Fairness	Non-Discrimination	Fairness	Data quality

P12 Security	Art. 15	Manage	Robustness	Safety	Robustness	Threat modeling

J.6 Jurisdictional Implementation Guidance

For EU Organizations:

1. EU AI Act compliance MANDATORY (high-risk, August 2, 2026)
2. Global Sigma certification demonstrates technical conformity with Articles 9–15
3. Additional requirements: Notified Body assessment, CE marking, post-market monitoring
4. Recommendation: Dual-track (Global Sigma + EU AI Act compliance)

For US Organizations:

1. Sector-specific regulations apply (no horizontal AI law)
2. NIST RMF non-binding guidance; federal agencies may require alignment
3. Global Sigma certification demonstrates NIST RMF alignment
4. Recommendation: Comply with sector regulations; use Global Sigma for high-risk systems

For Multi-Jurisdictional Organizations:

1. Determine applicable regulatory framework (EU AI Act, sectoral US law, etc.)
2. Global Sigma provides single certification mechanism satisfying multiple frameworks
3. Maintain jurisdiction-specific legal compliance

J.7 Critical Legal Distinctions

Global Sigma Certification is NOT:

- ❌ CE marking or formal conformity assessment under EU AI Act
- ❌ Regulatory approval or authorization from government
- ❌ Guarantee of system safety or absence of risk
- ❌ Substitution for legal compliance in any jurisdiction

Global Sigma Certification IS:

- ✅ Independent, third-party verification of P1–P12 adherence
- ✅ Demonstration of consolidated Trustworthy AI conformity
- ✅ Auditable evidence of technical compliance with legal framework requirements
- ✅ Verification mechanism where frameworks provide only guidance

Organizations remain responsible for:

- Complying with all applicable legal frameworks in operating jurisdictions
- Conducting required conformity assessments and governance processes mandated by law
- Implementing organizational controls and post-market monitoring
- Maintaining insurance and indemnification

J.8 Research Validation Status

Quantitative Thresholds: Acceptance criteria (≥95% reproducibility, ≥0.80 disparate impact ratio, ≥80% attack surface protection) are aspirational targets pending operational validation.

Methodology Refinement: Audit methodologies and evidence standards may be updated based on real-world implementation feedback.

Framework Alignment: Mappings to existing frameworks current as of January 2026 but subject to update as external frameworks evolve.

No Legal Precedent: Global Sigma has not been validated by regulatory authorities or courts; legal interpretation may evolve.

Organizations adopting Global Sigma should:

- Document baseline metrics against current thresholds
- Participate in feedback and validation processes
- Anticipate methodological refinements in new versions
- Maintain compliance with legal frameworks independently of Global Sigma status

---

Annex K: Implementation Case Studies & Remediation Path

Derived from practical validation scenarios to illustrate standard applicability.

K.1. Purpose
This annex provides reference scenarios for organizations to understand how technical vetoes (NO-GO) are identified and subsequently resolved through specific architectural interventions.

K.2. Use Case: Judicial Risk Assessment & Sentencing (Tier 4 System)

- **Context:** An AI system used to support judicial decisions regarding recidivism and sentencing.
- **Initial Audit Findings:**
  - **P3 Violation:** Proprietary training logic prevented full knowledge sovereignty for court auditors.
  - **P11 Violation:** High concentration of historical bias in the "Training Set" without documented mitigation.
- **Technical Veto:** A structural veto was issued due to the lack of **P9 (Ethical Guardrails)** at the decision layer.
- **Remediation Applied:**
  1. Implementation of **P7 (Modularity)**: The risk-scoring engine was decoupled from the final recommendation UI.
  2. Hard-coded **Ethical Blocks**: Implementation of statutory limits that override AI suggestions if they exceed legal boundaries.
- **Certification Result: CERTIFIED** under Tier 4 Monitoring, requiring continuous immutable log submission.

Annex L: Scientific Roadmap & Open-Source Governance

Operational framework for the "Research Validation Edition" and community contributions.

L.1. The Validation Lifecycle
As a Research Validation Edition, Global Sigma evolves through peer-reviewed contributions. Each principle is backed by specific technical tasks (Task IDs) available in the global repository.

L.2. Contribution Workflow (Task ID System)
Researchers and developers can claim tasks to validate or refine specific sub-principles:

- **Task Identification:** Coded as `[Principle.Item-Type]` (e.g., `[P2.7-A]` for *Principle 2, sub-item 7, Academic validation*).
- **Submission:** Contributions must be submitted via Pull Request to the official GitHub repository and discussed in the `#papers` Slack channel.
- **Peer Review:** All technical changes undergo a double-blind review by the Technical Coordination Committee before merging into the normative body.

Annex M: Evidence Validation Handbook (Technical Guidelines)

Standardized criteria for auditors to evaluate evidence reliability.

M.1. Hierarchy of Evidence Levels

To ensure consistency across different auditing bodies, Global Sigma defines three levels of evidence:

1. **Level 1: Immutable Forensic Logs (Critical):** Cryptographically hashed logs stored in write-once-read-many (WORM) environments. Mandatory for **P5 (Continuous Auditability)** in Tier 3 and 4 systems.
2. **Level 2: Technical Artifacts (High):** Verified architecture diagrams, data lineage maps, and API endpoint documentation.
3. **Level 3: Declarative Evidence (Low):** Policy documents and self-signed affidavits. **Note:** Level 3 evidence is never sufficient on its own for T3 or T4 certification.

M.2. Specific Principle Evidence Samples

- **For P2 (Reproducible Determinism):** The organization must provide the exact environment manifest (e.g., Dockerfile/Singularity) and the fixed seed used for all stochastic operations.
- **For P3 (Knowledge Sovereignty):** Access to the "Golden Dataset" (a statistically significant subset of training data) for independent bias and accuracy validation by the auditor.

DOCUMENT METADATA

Document: GLOBAL SIGMA PUBLIC STANDARD v3.1

Status: Official Research Validation Edition (2026–2027)

Last Updated: January 2026

Next Review: Q3 2026

Nature: Technical verification mechanism for AI Governance

Scope: Tier 2 (Voluntary), Tier 3 (High-Risk), and Tier 4 (Critical-Risk) AI Systems

Framework Consolidation: EU AI Act, OECD, UNESCO, NIST, ISO/IEC, EC Guidelines

Principles: 12 Operationalized Principles (P1–P12)

Risk Tiers: 4 (Tier 1–4)

Audit Phases: 6 (Scope → Evidence → Evaluation → Veto → Aggregation → Decision)

Annexes: 13 Normative Annexes (A–M)

Total Coverage: Complete operational framework for technical conformity and certification

---

END OF GLOBAL SIGMA PUBLIC STANDARD v3.1